

Executive Summary

RISK SCORE
69

GRADE
D

TOTAL FINDINGS
9

CRITICAL / HIGH
3 / 5

MEDIUM / LOW
1 / 0

Findings

Severity	Rule	Resource	Description
Critical	NET-001	aws_security_group.open_web_server	Security group has an ingress rule open to 0.0.0.0/0, allowing unrestricted access from the internet. This poses a significant security risk and should be restricted to specific IP ranges or removed if not necessary.
Critical	STG-001	aws_s3_bucket_public_access_block.app_bucket	S3 bucket does not block public ACLs. Objects in this bucket can be made publicly accessible via ACL grants.
Critical	STG-001	aws_s3_bucket_public_access_block.app_bucket	S3 bucket does not block public bucket policies. A bucket policy could expose this bucket's contents to the public internet.
High	IAM-001	aws_iam_policy.admin_policy	IAM policy grants wildcard (*) Action, allowing the attached principal to perform any AWS action.
High	IAM-001	aws_iam_policy.admin_policy	IAM policy grants access to wildcard (*) Resource, allowing actions on every resource in the AWS account.
High	ENC-001	aws_s3_bucket.app_bucket	S3 bucket does not have server-side encryption configured. Objects stored in this bucket are not encrypted at rest.
High	ENC-001	aws_db_instance.main_database	RDS database instance has storage encryption disabled. Database files, backups, and snapshots are stored unencrypted.
High	ENC-001	aws_ebs_volume.data_volume	EBS volume is not encrypted. Data stored on this volume is readable if the underlying storage is accessed directly.
Medium	LOG-001	aws_cloudtrail.main_trail	CloudTrail has logging explicitly disabled. API activity in this AWS account is not being recorded, making security incidents undetectable and unauditable.

Remediation Steps

[Critical]aws_security_group.open_web_server

Review the security group rules and restrict access to specific IP ranges or remove the open rule if it's not necessary.

[Critical]aws_s3_bucket_public_access_block.app_bucket

Set block_public_acls = true in your aws_s3_bucket_public_access_block resource to prevent public ACL grants on this bucket.

[Critical]aws_s3_bucket_public_access_block.app_bucket

Set block_public_policy = true in your aws_s3_bucket_public_access_block resource to prevent public bucket policies.

[High]aws_iam_policy.admin_policy

Replace Action: '*' with only the specific actions this principal needs. Follow the principle of least privilege.

[High]aws_iam_policy.admin_policy

Replace Resource: '*' with the specific ARNs of the resources this principal needs to access.

[High]aws_s3_bucket.app_bucket

Add a server_side_encryption_configuration block to your aws_s3_bucket resource with AES256 or aws:kms encryption.

[High]aws_db_instance.main_database

Set storage_encrypted = true on your aws_db_instance resource. Note: encryption cannot be enabled on an existing instance — a snapshot restore to a new encrypted instance is required.

[High]aws_ebs_volume.data_volume

Set encrypted = true on your aws_ebs_volume resource. You may also specify a KMS key with kms_key_id for additional control.

[Medium]aws_cloudtrail.main_trail

Set enable_logging = true on your aws_cloudtrail resource. Ensure the trail is also configured to log to a protected S3 bucket.

Score Methodology

Critical

Weight: 10 pts each
Grade A: 0–20

High

Weight: 7 pts each
Grade B: 21–40

Medium

Weight: 4 pts each
Grade C: 41–60

Low

Weight: 1 pt each
Grade D: 61–80